

Stručni kurs Razvoj bezbednog softvera

Izveštaj

David Toholj
09.09.2025.

Uvod

Ovaj izveštaj se bavi ranjivostima pronađenim u dole opisanoj veb aplikaciji.

Napomena: Sve izmene u kodu pogledati u istoriji komitova.

O veb aplikaciji

RealBookStore je veb aplikacija koja pruža mogućnosti pretrage, ocenjivanja i komentarisanja knjiga.

Aplikacija RealBookStore omogućava:

- Pregled i pretragu knjiga.
- Dodavanje nove knjige.
- Detaljan pregleda knjige kao i komentarisanje i ocenjivanje knjige.
- Pregled korisnika aplikacije.
- Detaljan pregled podataka korisnika.

SQL injection & Cross-site scripting

Napad: Ubacivanje novog usera u tabelu "persons"

Metod napada:

Na stranici books/{id} aplikacije, uneti sledeći tekst u input polje "Add comment":

```
I enjoyed this book... after making sure Gotham was safe'); insert into
persons(firstName, lastName, email) values ('David', 'Toholj', '<img src =
"x" onerror="alert(document.cookie)">')--
```

Predlog odbrane:

SQL Injection: Koristi se PreparedStatement umesto Statement jer se u tom slučaju input tretira kao obični podaci čime se sprečava napad.

XSS: Koristi se textContent umesto innerHTML jer se u tom slučaju input tretira kao običan tekst, a ne HTML.

Dokaz:

1. Unošenje komentara

Description:

Set in Middle-earth, the story began as a sequel to Tolkien's 1937 children's book *The Hobbit*, but eventually developed into a much larger work.

Author: **J.R.R. Tolkien**

Genres:

- epic fantasy
- sci-fi

Overall rating: **4.6666665**

My rating: **5**

○ 1 ○ 2 ○ 3 ○ 4 ○ 5 Rate

Book comments

Bruce Wayne

They are taking the hobbits to Isengard. P.S. I am not Batman

Bruce Wayne

I enjoyed this book... after making sure Gotham was safe.

Add comment

Comment...

Create comment

2. Prikaz korisnika nakon unošenja komentara

Users

Search...

Search

#	First Name	Last Name	Email	
1	Bruce	Wayne	notBatman@gmail.com	View profile
2	Sam	Vimes	night-watch@gmail.com	View profile
3	Tom	Riddle	theyGotMyNose@gmail.com	View profile
4	Quentin	Tarantino	qt5@gmail.com	View profile
5	David	Toholj		View profile

3. Pretraga korisnika nakon unosa komentara

localhost:8080/persons

localhost:8080 says

OK

ok Store Books Users

Users

dav

Search

You searched for dav

#	First Name	Last Name	Email
5	David	Toholj	View profile

© 2023 Copyright: [RBS](#)

4. Unošenje komentara nakon implementacije odbrane

Description:

Set in Middle-earth, the story began as a sequel to Tolkien's 1937 children's book *The Hobbit*, but eventually developed into a much larger work.

Author: J.R.R. Tolkien

Genres:

- epic fantasy
- sci-fi

Overall rating: 4.6666665

My rating: 5

☐ 1 ☐ 2 ☐ 3 ☐ 4 ☒ 5 [Rate](#)

Book comments

Bruce Wayne

They are taking the hobbits to Isengard. P.S. I am not Batman

Bruce Wayne

I enjoyed this book... after making sure Gotham was safe); insert into persons(firstName, lastName, email) values ('David', 'Toholj', )--

Add comment

Comment...

[Create comment](#)

© 2023 Copyright: [RBS](#)

Cross-site request forgery

Napad: Menjanje podataka korisnika

Metod napada:

Klikom na sliku, pokreće se exploit koji šalje zahtev serveru i menja podatke korisnika sa id = 1, tako da je firstName = "Batman" i lastName = "Dark Knight".

Predlog odbrane:

Na serveru se pri generisanju stranice kreira jedinstveni **CSRF token**, koji se prosleđuje korisniku i ubacuje u formu kao skriveno polje. Kada korisnik pošalje POST zahtev, token se vraća serveru i proverava njegova ispravnost. Na taj način napadač ne može da konstruiše validan zahtev bez posedovanja važećeg tokena, čime se onemogućava CSRF napad.

Dokaz:

1. Rezultat napada

Real Book Store Books Users

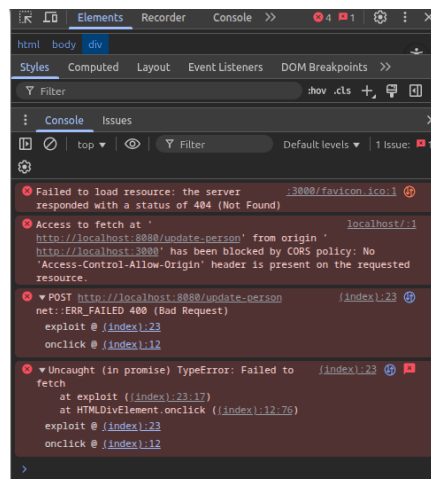
Users

Search... Search

#	First Name	Last Name	Email	
1	Batman	Dark Knight	notBatman@gmail.com	View profile
2	Sam	Vimes	night-watch@gmail.com	View profile
3	Tom	Riddle	theyGotMyNose@gmail.com	View profile
4	Quentin	Tarantino	qt5@gmail.com	View profile

© 2023 Copyright: RBS

2. Pokušaj napada nakon implementacije odbrane



3. Prikaz korisnika nakon neuspelog pokušaja napada

Real Book Store Books Users

Users

#	First Name	Last Name	Email	
1	Bruce	Wayne	notBatman@gmail.com	View profile
2	Sam	Vimes	night-watch@gmail.com	View profile
3	Tom	Riddle	theyGotMyNose@gmail.com	View profile
4	Quentin	Tarantino	qt5@gmail.com	View profile

© 2023 Copyright: [RBS](#)

Autorizacija

Implementacija:

Koriste se **Spring Security** i **Thymeleaf** koncepti. Uvedene role:

Permisija	ADMIN	MANAGER	REVIEWER	Opis
ADD_COMMENT	*	*	*	Dozvoljava korisniku da doda komentar.
VIEW_BOOKS_LIST	*	*	*	Dozvoljava korisniku da vidi i pretraži listu knjiga.
CREATE_BOOK	*	*	X	Dozvoljava korisniku da unese novu knjigu.
VIEW_PERSONS_LIST	*	*	X	Dozvoljava korisniku da vidi i pretraži listu korisnika.
VIEW_PERSON	*	X	X	Dozvoljava korisniku da vidi detalje osobe.
UPDATE_PERSON	*	* - pogledati napomenu	* - pogledati napomenu	Dozvoljava korisniku da promeni detalje osobe (isto važi za brisanje korisnika).
VIEW_MY_PROFILE	*	*	*	Dozvoljava pregled sopstvenog profila.
RATE_BOOK	*	*	*	Dozvoljava da korisnik oceni knjigu.

Napomena: Rolama *MANAGER* i *REVIEWER* je dozvoljena promena isključivo svojih sopstvenih podataka.

Dokaz:

1. Pogled ADMIN

Real Book Store Books Users

Users

Search...				Search
#	First Name	Last Name	Email	
1	Bruce	Wayne	notBatman@gmail.com	View profile
2	Sam	Vimes	night-watch@gmail.com	View profile
3	Tom	Riddle	theyGotMyNose@gmail.com	View profile
4	Quentin	Tarantino	qt5@gmail.com	View profile

© 2023 Copyright: [RBS](#)

2. Pogled MANAGER

Real Book Store Books Users

Users

Search...				Search
#	First Name	Last Name	Email	
1	Bruce	Wayne	notBatman@gmail.com	
2	Sam	Vimes	night-watch@gmail.com	
3	Tom	Riddle	theyGotMyNose@gmail.com	
4	Quentin	Tarantino	qt5@gmail.com	

© 2023 Copyright: [RBS](#)

3. Pogled REVIEWER

Real Book Store Books

Books

				Search
#	Title	Description	Author	
1	The Lord of the Rings	Set in Middle-earth, the story began as a sequel to Tolkien's 1937 children's book The Hobbit, but eventually developed into a much larger work.	J.R.R. Tolkien	Details
2	Dune	Dune is set in the distant future in a feudal interstellar society in which various noble houses control planetary fiefs.	Frank Herbert	Details
3	Grundrisse	The series of seven notebooks rough-drafted by Marx, chiefly for purposes of self-clarification, during the winter of 1857-8.	Karl Marx	Details

© 2023 Copyright: [RBS](#)

DevOps

Implementacija:

1. Uvedena **obrada i logovanje svih izuzetaka** u aplikaciji.
2. Uveden **auditing**.